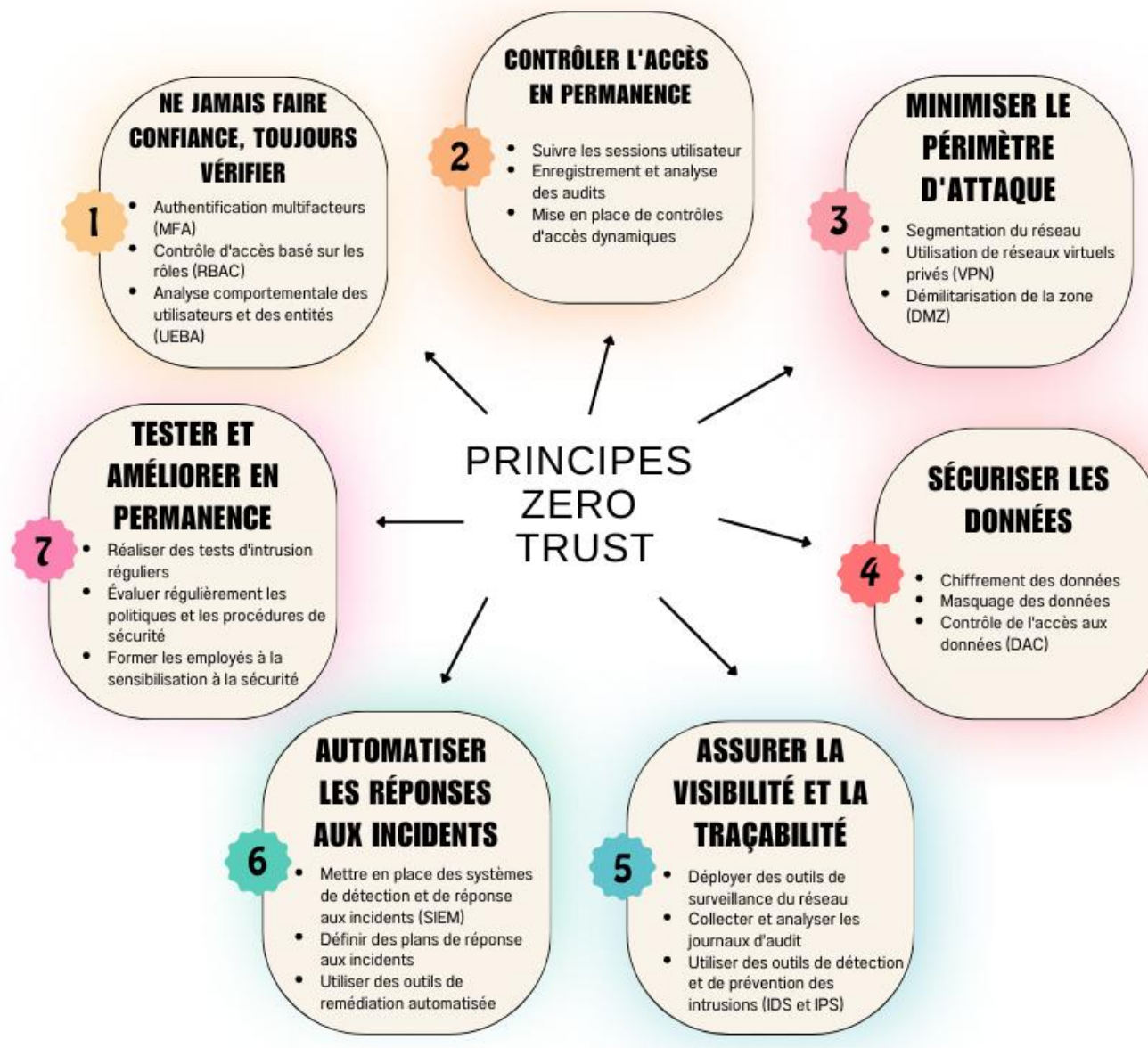


Veille technologique

ZERO TRUST

Laureen RUELLE
MFR DE ST EGREVE



Les grands principes du modèle Zéro Trust

Le modèle de sécurité Zéro Trust repose sur plusieurs principes fondamentaux qui guident sa mise en œuvre et garantissent une forte sécurité :

- **La vérification continue.** Ne jamais faire confiance, toujours vérifier. Cela signifie que chaque utilisateur, dispositif ou application est à vérifier systématiquement lors de sa tentative d'accès au réseau, indépendamment de son emplacement et même s'il y a déjà accédé précédemment.
- **Le droit d'accès minimal.** Les utilisateurs et les dispositifs ne doivent avoir accès qu'aux ressources dont ils ont besoin pour accomplir leurs tâches spécifiques. Cela réduit les risques de subir des attaques en cas d'identifiants volés ou des menaces internes.
- **Micro segmentation** Diviser le réseau en sections plus petites et isolées permet de contenir les failles de sécurité et empêche le mouvement latéral des cybercriminels.
- **L'authentification multi facteur.** Instaurer plusieurs facteurs d'authentification (en exigeant par exemple un mot de passe, un code de sécurité à usage unique et la vérification biométrique) complique considérablement les tentatives d'accès d'utilisateurs non autorisés.
- **La visibilité accrue.** Une surveillance et une journalisation complètes de l'activité réseau fournissent des informations précieuses sur les menaces potentielles et aident les équipes de sécurité à réagir rapidement aux incidents.
- **La gestion unifiée des Endpoint.** La gestion centralisée des Endpoint, ou appareils, garantit des politiques de sécurité uniformes et simplifie le processus de vérification et de sécurisation des appareils en question.
- **L'EDR (Endpoint Detection and Response).** Les capacités de détection des menaces en temps réel et de réponse sur les Endpoint aident à identifier et neutraliser les activités malveillantes avant qu'elles ne puissent se propager.

En observant les principes du Zero Trust, les entreprises créeront un environnement particulièrement sécurisé, à même de repousser les cyberattaques d'aujourd'hui.

Pourquoi j'ai été intéressée par ce sujet ?

- La cybersécurité est centrale en SISR
- Sujet **très actuel**
- Facile à relier aux pare-feu, VPN, Active Directory, VLAN, MFA

Quel est le principe ?

"Never trust, Always verify"

Même si un utilisateur est dans le réseau interne → il doit être authentifié et contrôlé.

Traditional Security

Where are you coming from?



Zero Trust

Who are you?



Les éléments clés :

- Authentification forte (MFA) : L'authentification multi facteur (MFA) **ajoute une couche de protection au processus de connexion**. Pour accéder à leurs comptes ou à des applications, les utilisateurs doivent confirmer leur identité, par exemple en scannant leur empreinte ou en entrant un code reçu par téléphone.
- Gestion des identités (IAM) : Utiliser la gestion des identités et des accès AWS (IAM) pour gérer et mettre à l'échelle l'accès aux charges de travail et à la main-d'œuvre en toute sécurité afin d'optimiser votre agilité et votre innovation dans AWS.
- Segmentation réseau
- Contrôle d'accès basé sur les rôles
- Journalisation et supervision (SIEM) : La surveillance des journaux SIEM est un processus qui consiste à collecter, agréger et analyser les données de journaux générées à partir de diverses sources, telles que les périphériques réseau, les serveurs, les applications et les systèmes de sécurité. L'objectif principal de la surveillance des journaux SIEM est de détecter les activités inhabituelles ou suspectes et d'alerter les équipes de sécurité en cas d'incidents potentiels. Les systèmes SIEM offrent une meilleure visibilité sur les environnements informatiques, ce qui permet une détection plus efficace des menaces, une meilleure gestion de la conformité et une réponse plus rapide aux incidents.

Les 5 piliers du modèle de sécurité Zéro Trust

Le Zéro Trust est un modèle de cybersécurité qui requiert une vérification continue de tous les utilisateurs et dispositifs, quel que soit l'emplacement. Voici les cinq piliers du modèle Zéro Trust qui renforcent la sécurité réseau :

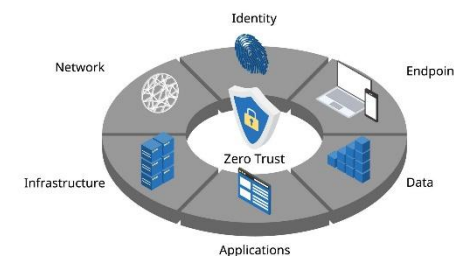
1. Identité : La sécurité réseau Zéro Trust authentifie les utilisateurs et accorde un accès uniquement aux utilisateurs ou aux ressources de l'entreprise approuvés. Les systèmes de gestion des identités et des accès (GIA), l'authentification unique (SSO) et l'authentification multifactorielle (MFA) sont des outils très appréciés qu'adoptent les entreprises la vérification des identités.

2. Réseaux : Contrairement à la segmentation traditionnelle du réseau, le Zéro Trust permet la micro segmentation, séparant les ressources et charges de travail en tout petits groupes sécurisés. Cela aide les entreprises à contenir les violations et empêcher tout mouvement latéral. Les acteurs malveillants ne peuvent pas accéder aux ressources qu'ils ne sont pas autorisés à utiliser.

3. Dispositifs : L'ensemble des dispositifs, y compris les ordinateurs portables, téléphones mobiles, serveurs, appareils connectés étiquetés « IdO », imprimantes et divers appareils présents sur le réseau, sont régis par les règles Zéro Trust et subissent les contrôles de sécurité de l'entreprise. Le modèle Zéro Trust conserve des inventaires complets de tous les Endpoint autorisés et refuse l'accès au réseau aux dispositifs non autorisés.

4. Applications et charges de travail : En vertu du modèle Zéro Trust, on ne fait confiance ni aux applications, ni aux interfaces de programmation d'applications (API). Les entreprises effectuent des vérifications systématiques à chaque tentative d'accès, plutôt que de donner un accès permanent. Elles surveillent également les interactions entre les applications pour détecter toute activité inhabituelle.

5. Données : Les entreprises adoptant le modèle Zéro Trust classent l'ensemble de leurs données pour appliquer des contrôles d'accès et des politiques de sécurité spécifiques pour les protéger. Les données transférées, utilisées ou stockées sont protégées par le chiffrement et l'autorisation dynamique. De plus, les entreprises surveillent l'activité des données pour détecter tout indice de violation ou d'accès non autorisé.



Source : <https://www.fortinet.com/fr/resources/cyberglossary/what-is-the-zero-trust-network-security-model>